

Cybersécurité TH1_TP1



Sommaire :

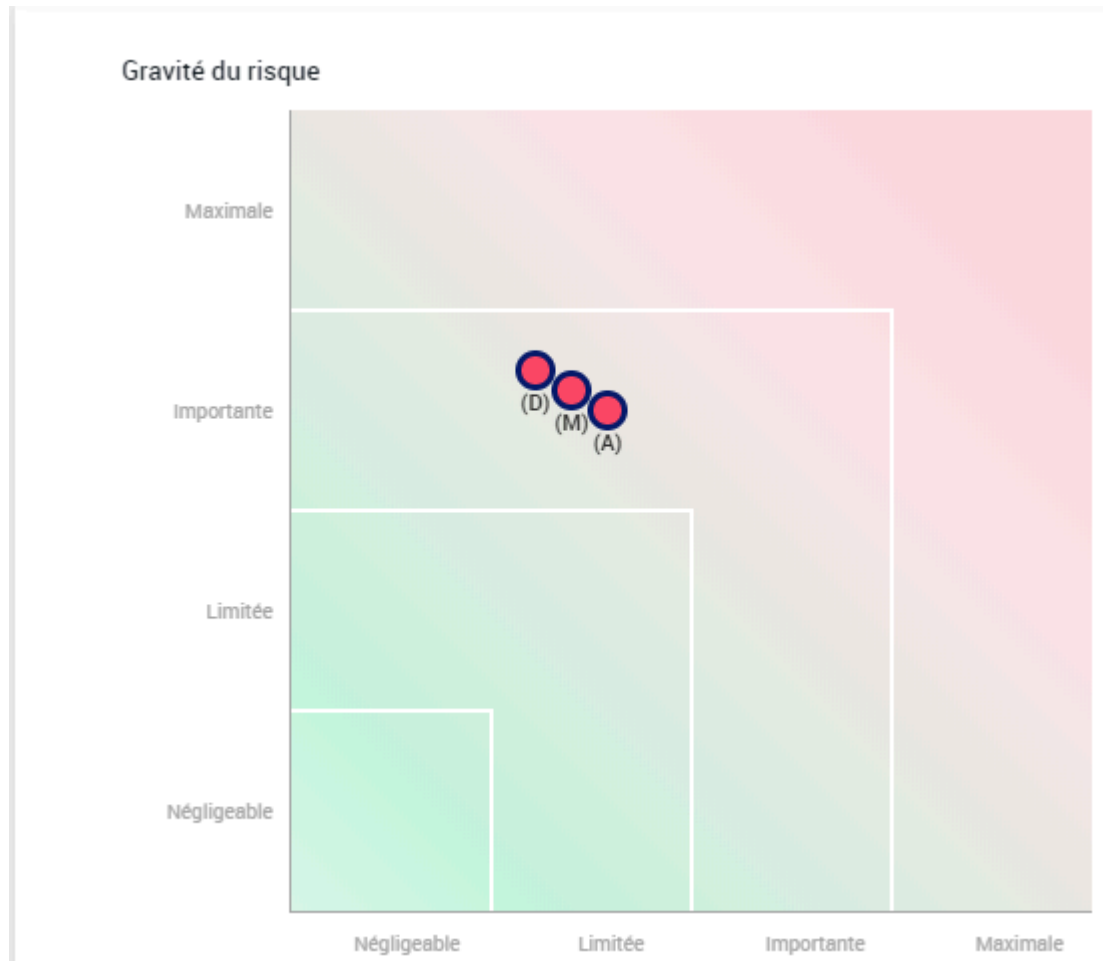
Sommaire

1. [Introduction](#)
2. [Analyser un PIA](#)
3. [Cartographier le traitement des données](#)
4. [Repérer l'utilisation des données personnelles](#)
5. [Traitements et risques sur les données](#)
6. [Sécurité vs Sûreté informatique](#)
7. [Identifier les données à caractère personnel](#)
8. [Conclusion](#)

Introduction :

Ce dossier présente l'analyse des risques liés aux données personnelles dans un processus de recrutement via le PIA.

1. Analyser un PIA



A = Accès illégitime à des données

M = Modification non désirée de données

D = Disparition de données

Accès illégitime à des données :

Le risque peut entraîner des conséquences graves sur la santé et la sécurité des personnes, avec des impacts potentiels durables malgré les mesures déjà en place.

La gravité est importante. Un salarié mal intentionné ou un attaquant externe pourrait faire de gros dégâts dans la base de données

Les menaces identifiées sont fréquentes dans le contexte notamment du fait d'erreurs humaines récurrentes et d'une infrastructure partiellement obsolète.

La vraisemblance est de niveau 2 , peu probable.

Modification non désirée de données :

La gravité est importante, le risque présente une atteinte à la sécurité des personnes et à la confidentialité des données. Il représente un impact lourd pour l'organisation en cas d'échec

La vraisemblance est estimée probable, étant donné la fréquence des menaces identifiées

Disparition de données :

La gravité est importante, les impacts peuvent gravement affecter la santé et la sécurité des personnes. Bien que des mesures soient en place, la nature du risque le rend susceptible d'entraîner des conséquences sérieuses.

Le niveau de vraisemblance est limité, les mesures existantes réduisent la probabilité du risque, mais des menaces restent présentes.

- Modification non désirée : sauvegardes régulières, contrôle des droits d'accès, vérification d'intégrité
- Disparition de données : sauvegardes redondantes, stockage sécurisé, procédures de restauration testées

Évolution de la cartographie :

Les mesures réduisent la vraisemblance des risques. La cartographie évolue vers une zone plus maîtrisée, avec des risques mieux encadrés.

2. Cartographier le traitement des données

Définition et enjeux : La cartographie des traitements permet d'identifier tous les flux de données personnelles dans une organisation. Elle aide à repérer les risques, à respecter la réglementation et à mettre en place des mesures de sécurité adaptées.

Rôle du registre des traitements : Le registre est une étape préalable car il recense tous les traitements. Il sert de base pour construire la cartographie en identifiant les données, les finalités, les acteurs et les risques.

3. Repérer l'utilisation des données personnelles

1. Conséquences de la saisie sur castorama.fr : Les données peuvent être partagées avec d'autres entités du groupe Kingfisher et des tiers pour des analyses, du marketing ou des actions juridiques. Cela implique un risque de diffusion non maîtrisée.

2. Confidentialité assurée ? : Non, la seule lecture ne permet pas d'affirmer que la confidentialité est assurée. Le texte mentionne des

partages avec des tiers, mais ne détaille pas les mesures de protection mises en place.

4. Traitements et risques sur les données

1. Moyens de collecte, stockage et diffusion

Collecte : formulaires, navigation web

Stockage : bases de données, serveurs

Diffusion : partage avec partenaires, marketing, cloud

2. Traitements présentés : Collecte, enregistrement, analyse, transmission, suppression

3. Obligations légales : Consentement, transparence, droit d'accès, sécurité, minimisation des données

4. Sanctions en cas de non-respect : Amendes jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial, sanctions pénales, réputation endommagée

5. Sécurité vs Sûreté informatique

Scénarios	Sécurité	Sûreté	Justifications
L'ensemble des serveurs est hors-service à cause d'une inondation du local technique	☐	☐	
Les données d'un hôpital sont illisibles à la suite d'une attaque de type <i>ransomware</i> .	☐	☐	
L'apparence du site vitrine d'une entreprise est modifiée pendant un week-end par des personnes malveillantes.	☐	☐	
Une surcharge électrique temporaire due à des travaux réalisés dans les bâtiments de la société provoque une panne des routeurs.	☐	☐	

1. Sûreté | Risque physique externe, donc sûreté
2. Sécurité | Attaque informatique, donc sécurité
3. Sécurité | Intrusion numérique, donc sécurité
4. Sûreté | Incident technique externe, donc sûreté

6 Identifier les données à caractère personnel

Données	Caractère personnel	Justifications
Le nom de l'enseigne du magasin Carrefour	☐ oui ☐ non	
L'adresse courriel professionnelle d'un directeur des services informatiques	☐ oui ☐ non	
Une photo postée sur un réseau social	☐ oui ☐ non	
Une vidéo de présentation de son parcours professionnel envoyée à une entreprise dans le cadre d'un recrutement	☐ oui ☐ non	
Les coordonnées GPS de localisation d'un smartphone	☐ oui ☐ non	
Le groupe sanguin d'un patient stocké sur le serveur de base de données de son médecin	☐ oui ☐ non	
Les enregistrements de vidéosurveillance d'un <i>datacenter</i>	☐ oui ☐ non	
Le numéro d'enregistrement au registre du commerce et des sociétés d'une entreprise	☐ oui ☐ non	
Le numéro de sécurité sociale d'un salarié saisi sur sa fiche d'embauche	☐ oui ☐ non	

Donnée	Caractère personnel	Justification
Nom de l'enseigne Carrefour	Non	Ce n'est pas une personne physique
Adresse courriel pro d'un directeur informatique	Oui	Identifie une personne dans son rôle professionnel
Photo postée sur un réseau social	Oui	Permet d'identifier une personne
Vidéo de présentation envoyée pour un recrutement	Oui	Contient des informations personnelles et professionnelles
Coordonnées GPS d'un smartphone	Oui	Permet de localiser une personne
Groupe sanguin d'un patient	Oui	Donnée de santé liée à une personne
Enregistrements de vidéosurveillance d'un datacenter	Oui	Peut contenir des images de personnes identifiables
Numéro d'enregistrement au registre du commerce d'une entreprise	Non	Identifie une entité juridique, pas une personne physique
Numéro de sécurité sociale d'un salarié	Oui	Donnée personnelle sensible liée à une personne

Conclusion :

La mise en place de mesures correctrices améliore la sécurité et garantit la conformité au RGPD.